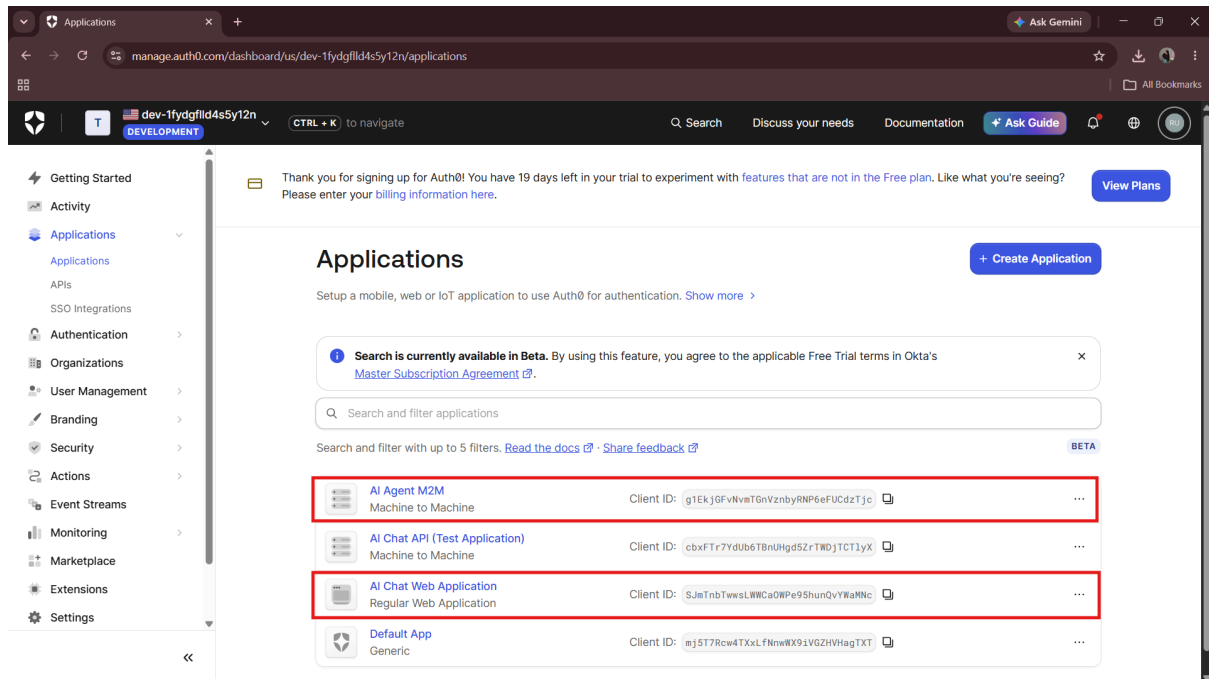


CAPSTONE PROJECT DOCUMENTATION

PROJECT 2 : Auth0 Implementation

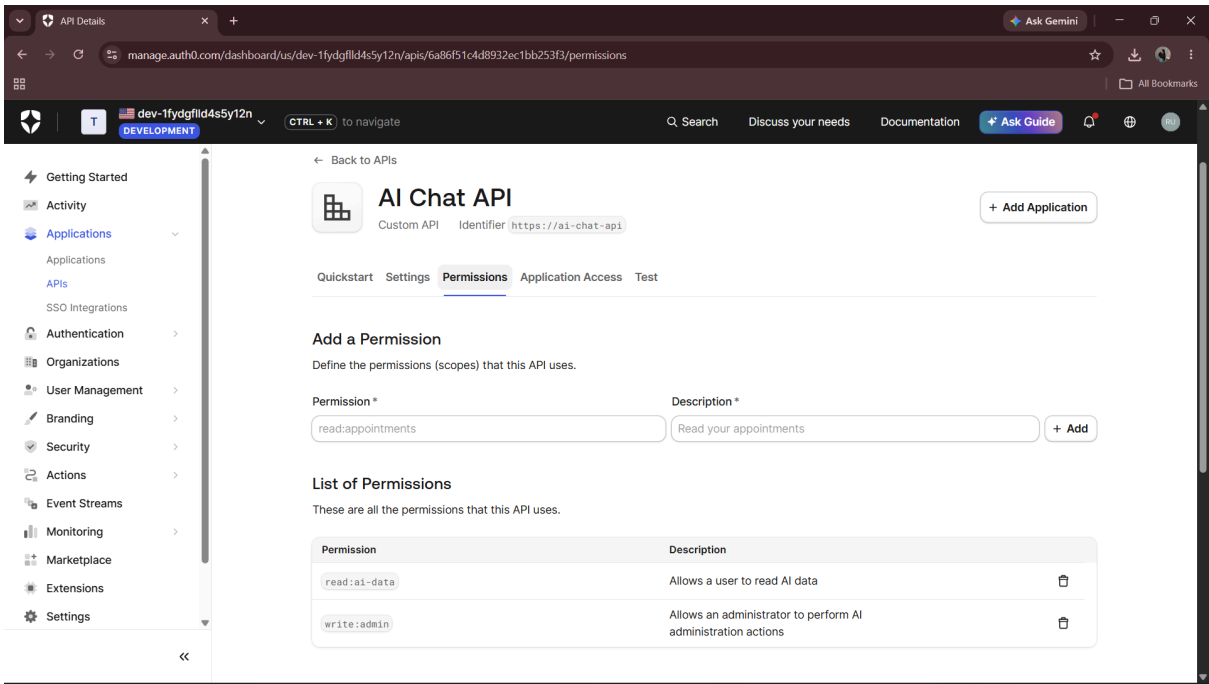
Screenshot 1: Auth0 Applications Configuration

This screenshot shows the Auth0 Applications page with both required application types registered. The AI Agent M2M application is configured as a Machine to Machine application, while the AI Chat Web Application is configured as a Regular Web Application, demonstrating separate identity flows for machine-to-machine and user authentication.



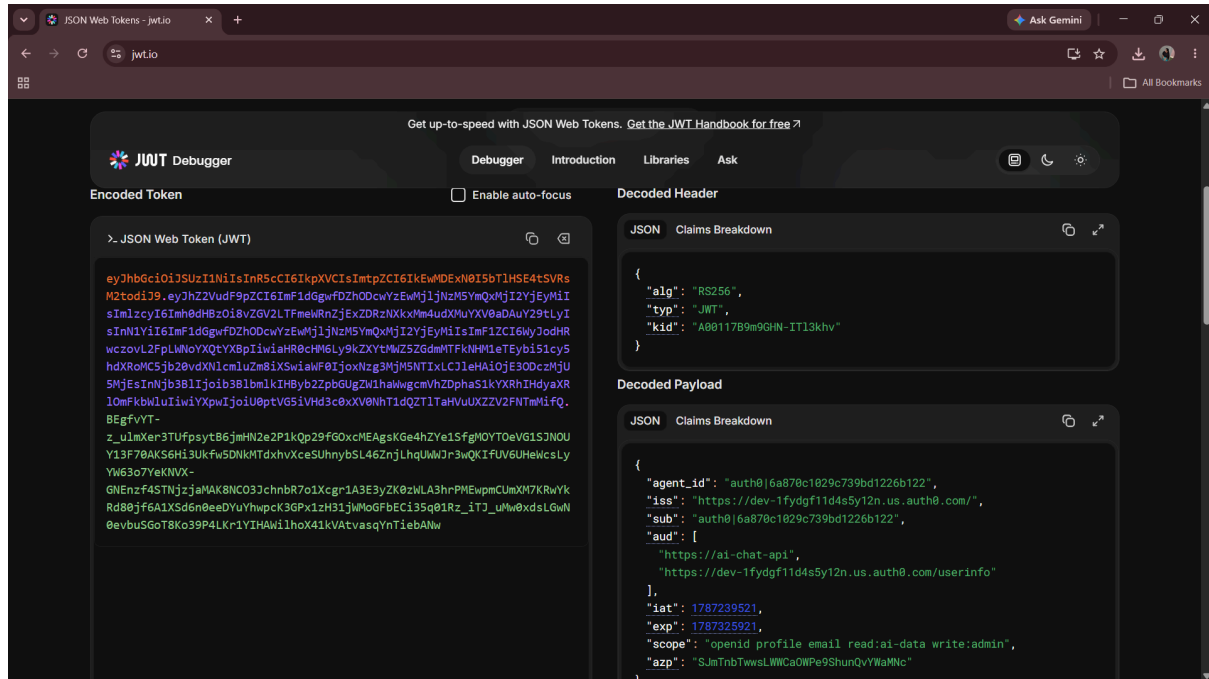
Screenshot 2: Auth0 API Permissions

This screenshot shows the AI Chat API with the two custom authorization scopes configured: read:ai-data for reading AI data and write:admin for administrative AI actions. These permissions provide fine-grained authorization for the application and API.



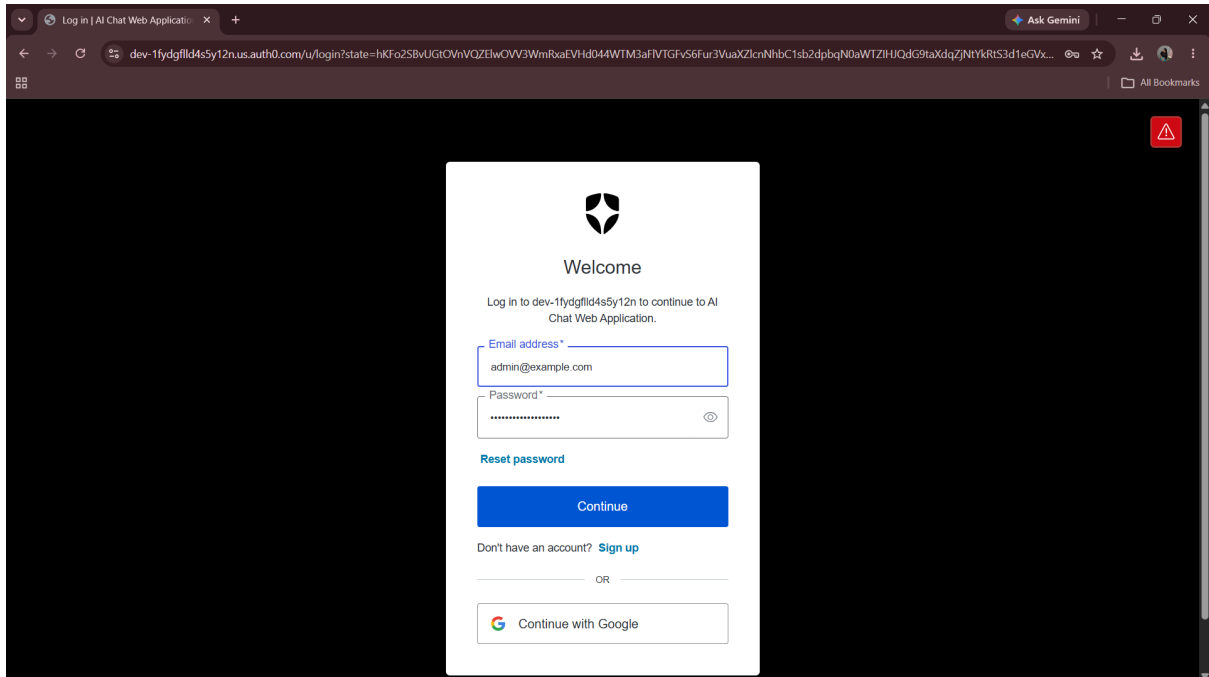
Screenshot 3: Decoded JWT and Agent Identity

This screenshot shows the issued JWT decoded in jwt.io. The payload visibly contains the audience (aud), issuer (iss), expiration time (exp), authorization scope, and the custom agent_id claim, providing evidence of the token's identity and authorization information.



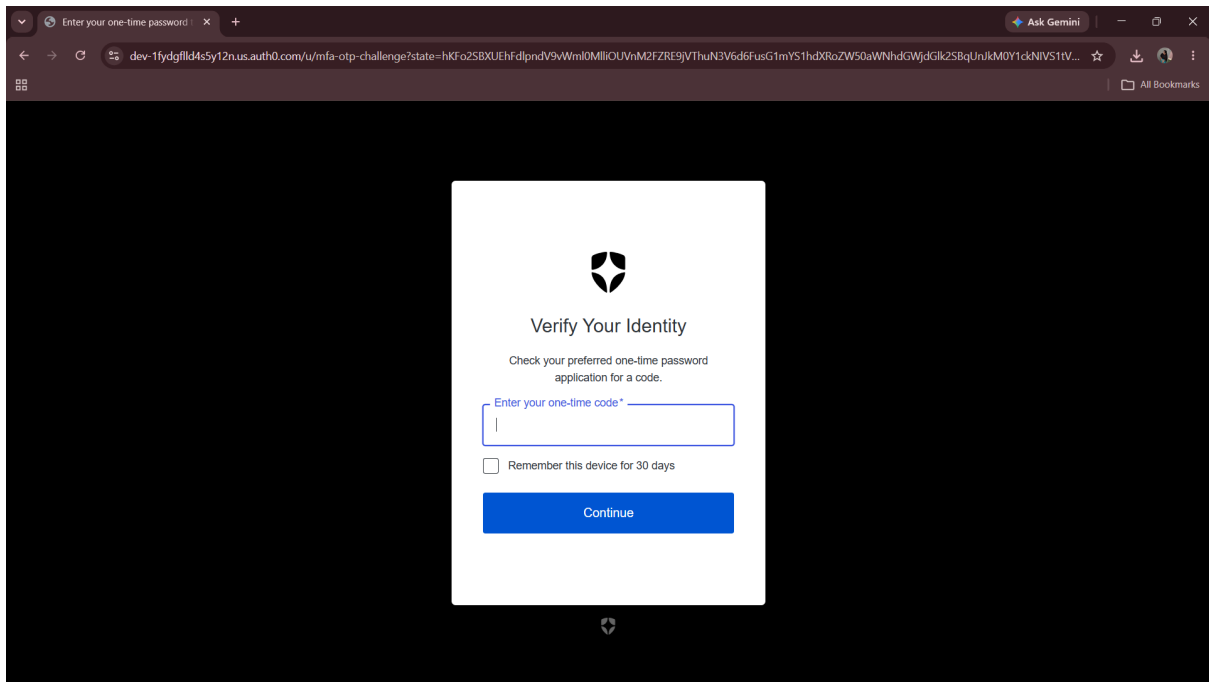
Screenshot 4: Auth0 Universal Login Branding

This screenshot shows the Auth0 Universal Login experience for the AI Chat Web Application. The branded login page demonstrates that authentication is being handled through Auth0 Universal Login with the configured tenant/application presentation.



Screenshot 5: Multi-Factor Authentication (MFA) Enrollment

This screenshot shows the Auth0 TOTP challenge presented after primary authentication. The user is required to enter a one-time password from an authenticator application, demonstrating the configured multi-factor authentication control.



Enter your one-time password

dev-1fydgfild4s5y12n.us.auth0.com/u/mfa-otp-challenge?state=hKfo2SBXUEHfJpndV9vWml0MIIIOUvNm2FZRE9jVThuN3V6d6FusG1mYS1hdXR0ZW50aWNhdGJk2SBqUnJkM0Y1ckNlVS1tV...



Verify Your Identity

Check your preferred one-time password application for a code.

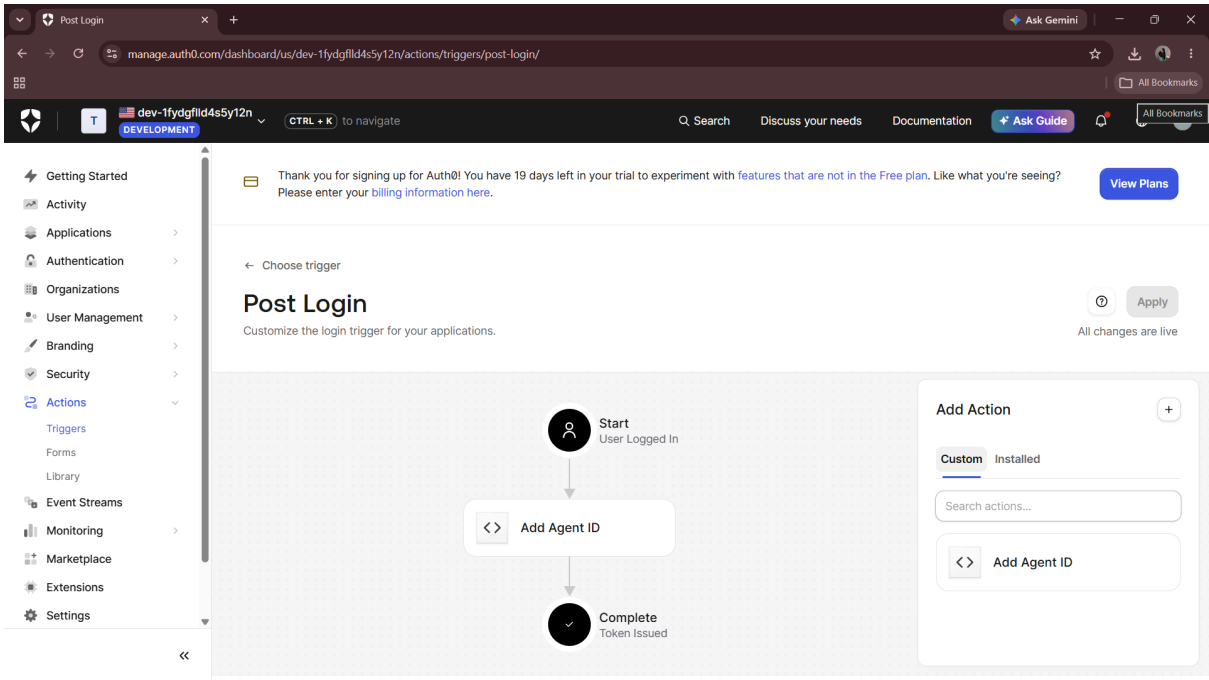
Enter your one-time code*

☐ Remember this device for 30 days

[Continue](#)

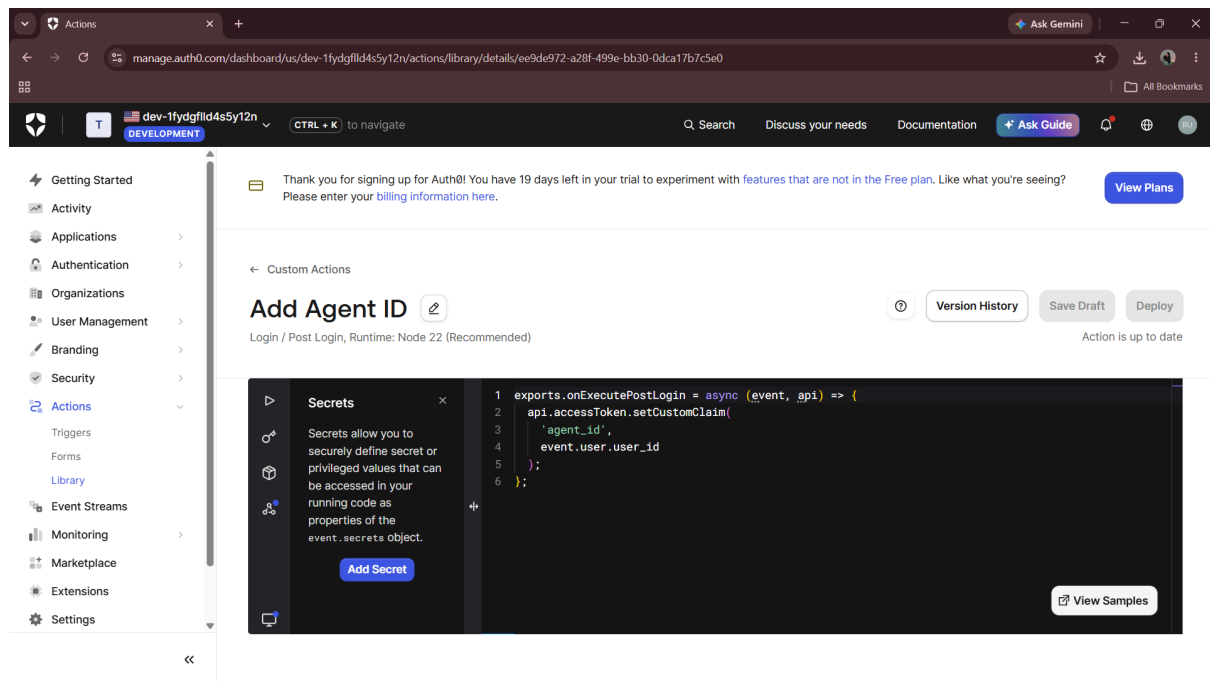
Screenshot 6: Post-Login Action Flow

This screenshot shows the Auth0 Post Login trigger with the Add Agent ID custom Action placed between the User Logged In start event and the Complete token-issued event. It demonstrates that the custom Action is attached to the post-login authentication flow.



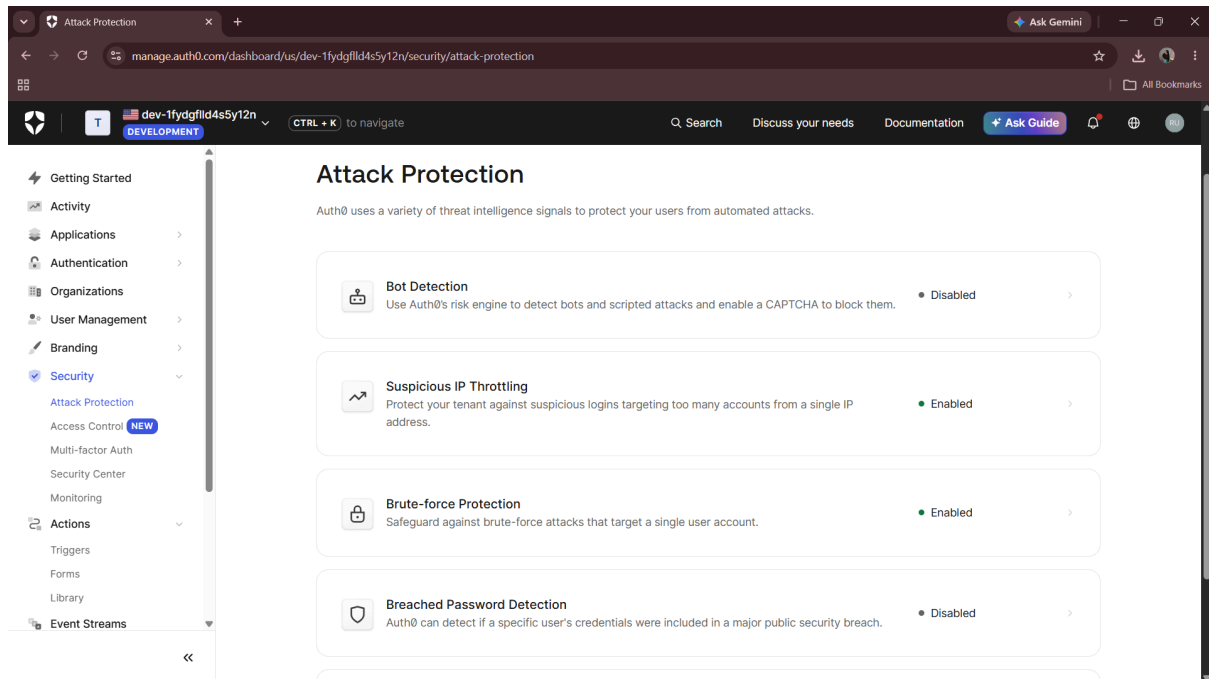
Screenshot 7: Post-Login Action Code

This screenshot shows the Add Agent ID Action editor. The Post-Login Action calls `api.accessToken.setCustomClaim()` to add the `agent_id` custom claim using the authenticated user identifier, ensuring the access token carries the required agent identity value.



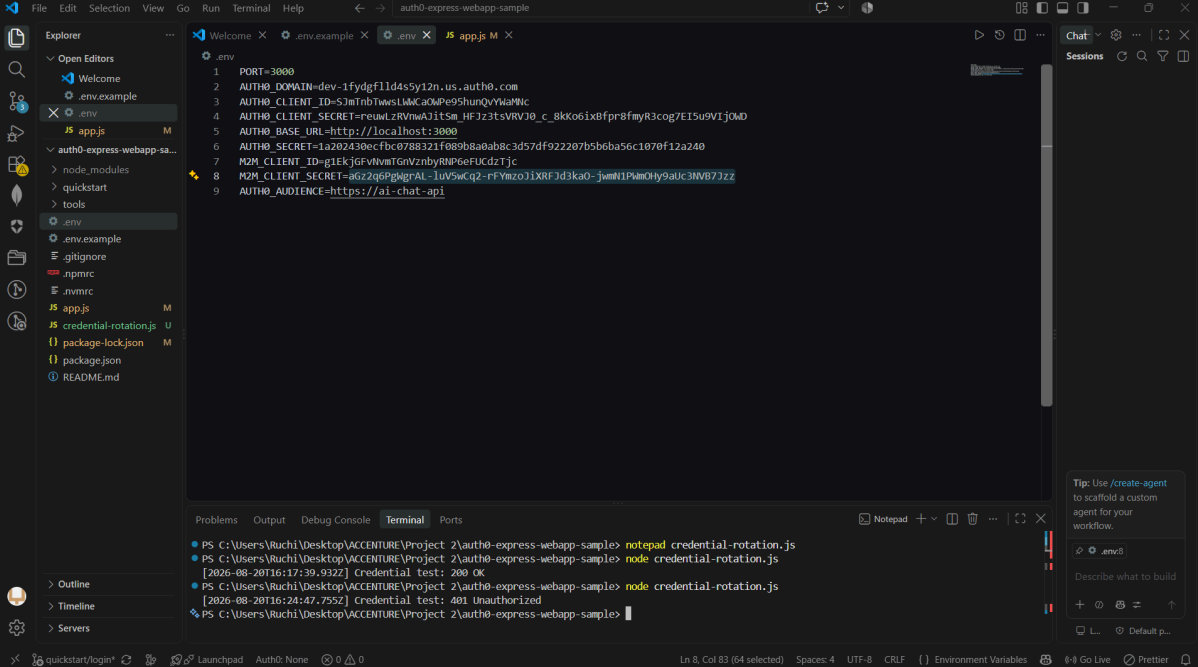
Screenshot 8: Auth0 Attack Protection

This screenshot shows the Auth0 Attack Protection panel with Suspicious IP Throttling enabled and Brute-force Protection enabled. These controls protect the tenant against repeated credential attacks and suspicious login activity from a single IP address.



Screenshot 9: Credential Rotation and Replay Test

This screenshot shows the credential rotation validation in the terminal. A timestamped credential test first returns 200 OK, and after the M2M client secret is rotated, replaying the old credential returns 401 Unauthorized, demonstrating that the previous credential is no longer accepted.



The screenshot displays the Visual Studio Code interface with a terminal window at the bottom. The terminal shows the execution of a script named `credential-rotation.js`. The output indicates that the initial credential test was successful (200 OK) at 2026-08-20T16:17:39.932Z. Following the rotation of the M2M client secret, a subsequent test at 2026-08-20T16:24:47.755Z failed with a 401 Unauthorized response, confirming that the old credential is no longer valid.

```
.env
1 PORT=3000
2 AUTH0_DOMAIN=dev-1fydgf1ld4s5y12n.us.auth0.com
3 AUTH0_CLIENT_ID=5JmTnbTwsUkcaQp9ShunQvYMa9tC
4 AUTH0_CLIENT_SECRET=reuwlzRVmAJlt5e_HFJz3tsVRVJ0_c_8kko6ixBfpr8fmyR3cog7E15u9V1jQmD
5 AUTH0_BASE_URL=http://localhost:3000
6 AUTH0_SECRET=1a202438ecfbc0788321f089b8a8ab8c3d57df922207b5b6ba56c1070f12a240
7 M2M_CLIENT_ID=g1EkjGfVnmITGnVznbYRNP6eFUCdZTjc
8 M2M_CLIENT_SECRET=aGz2q6pggrAL-luV5wCq2-FYmzoJ1XRFJd3ka0-jwmN1PmOhY9aUc3NV87Jzz
9 AUTH0_AUDIENCE=https://ai-chat-api

PS C:\Users\Ruchi\Desktop\VACCENTURE\Project 2\auth0-express-webapp-sample> notepad credential-rotation.js
PS C:\Users\Ruchi\Desktop\VACCENTURE\Project 2\auth0-express-webapp-sample> node credential-rotation.js
[2026-08-20T16:17:39.932Z] credential test: 200 OK
PS C:\Users\Ruchi\Desktop\VACCENTURE\Project 2\auth0-express-webapp-sample> node credential-rotation.js
[2026-08-20T16:24:47.755Z] credential test: 401 Unauthorized
PS C:\Users\Ruchi\Desktop\VACCENTURE\Project 2\auth0-express-webapp-sample>
```